Security Review

CLeverCVXLocker Convex On-Chain Voting Migration

July 29, 2026 — SECBIT Labs

1. Executive Summary

At the request of the AladdinDAO team, SECBIT Labs conducted a security review of the `CLeverCVXLocker` changes introduced in PR #274. The changes allow the Locker owner to authorize a designated address as a voting surrogate under Convex's new on-chain voting system.

No exploitable security vulnerabilities were identified in the reviewed source diff. The new surrogate authorization is restricted to the Locker owner, preserves the Locker as the voter account when the surrogate path is used, and does not grant the surrogate control over the Locker's assets or administrative functions. The reviewed source changes are suitable for merge.

The review also identified the following non-vulnerability observations that should be resolved or formally acknowledged before production deployment:

Observation	Classification	Status
An existing Gauge delegation from `CLeverCVXLocker` to the current owner Safe provides a second Gauge voting path.	Operational / Informational	Discussed
The legacy Snapshot and L2 voting selectors are removed from the new ABI.	Compatibility / Informational	Discussed
Voting-incentive attribution by Stake DAO, Votemarket, or other third-party platforms depends on their external accounting logic.	External Dependency / Informational	Discussed

These observations do not represent newly introduced security vulnerabilities. Production deployment remains conditional on completing the actions described in Sections 5 and 6.

2. Review Scope and Methodology

Item	Reviewed Value
Repository	AladdinDAO/aladdin-v3-contracts
Pull request	PR #274 — Convex on-chain voting migration
Base commit	`b8d232ba31abd2c815f5662e0bd99d26e09dd79a`
Reviewed commit	`25d83f1f34d0e59d41d11db7bc0ac137dc4dec35`
Reviewed files	`contracts/clever/CLeverCVXLocker.sol` and `contracts/interfaces/convex/IConvexSurrogateRegistry.sol`
Mainnet-fork baseline	Block `25,610,963`
Mainnet-state reference	Block `25,636,399`

The review covered the source diff, access-control boundaries, proxy-call semantics, storage compatibility, interaction with the Convex Surrogate Registry, DAO and Gauge voting behavior, revocation and replacement behavior, and the interaction between surrogate authorization and the existing Gauge delegation.

The conclusions in this report apply to the reviewed commit and to the external contract behavior observed during the review. The final production artifact and deployment transactions should be validated before execution.

3. Change Overview

Convex is migrating its Snapshot-based voting process to an on-chain voting system. Because CLever's CVX is locked through `CLeverCVXLocker` and provides approximately 3.2 million vlCVX voting power, the Locker requires a mechanism that allows an operational voting account to submit DAO and Gauge votes without transferring ownership of the voting position or the underlying assets.

PR #274 introduces:

- `setConvexVotingSurrogate(address)`, an owner-only function that calls the Convex shared Surrogate Registry at `0x8E4828a8C69A837F95Caa0D5e18fa09Ded12F73f`;
- `UpdateConvexVotingSurrogate(address)`, an event recording surrogate updates; and
- removal of the legacy `delegate(address,bytes32,address)` and `commitUserSurrogate(address,address,address)` selectors from the new Locker ABI.

The new function accepts `address(0)` to revoke the current surrogate.

4. Security Analysis

4.1 Surrogate Authorization and Delegation Are Distinct Mechanisms

Convex's Surrogate Registry and Delegation Registry serve different purposes.

Under the surrogate authorization introduced by this PR:

- the surrogate address sends the voting transaction;
- the voting call explicitly specifies `CLeverCVXLocker` as the account;
- the Vote Platform uses the Locker's vlCVX voting weight;
- vote records, `userInfo`, `getVote`, and voter-list entries are associated with the Locker; and
- the surrogate does not receive the Locker's underlying assets, rewards, or administrative permissions.

By contrast, Convex delegation aggregates voting weight into the delegate, which votes using its own account. The new `setConvexVotingSurrogate()` function does not create, modify, or revoke such a delegation.

4.2 Authorization Flow

Only the `CLeverCVXLocker` owner may call:

```
setConvexVotingSurrogate(address surrogate);
```

The Locker then calls:

```
SurrogateRegistry.setSurrogate(surrogate);
```

Because the external Registry call originates from the Locker proxy, the Registry records the authorization for `CLeverCVXLocker`, not for the implementation contract or the owner account.

When a vote is submitted, the Convex Vote Platform accepts the transaction only if the sender is either the specified account or that account's current surrogate. An unrelated address cannot use an arbitrary `account` parameter to bypass this authorization.

4.3 Privilege Boundaries

Surrogate authorization permits the designated address to exercise the Locker's DAO and Gauge voting power through compatible Convex Vote Platforms. It does not permit the surrogate to:

- withdraw or transfer CVX held by the Locker;
- modify user positions or debt;
- perform lock, unlock, borrow, or repay operations;
- call owner-only or keeper-only Locker functions; or
- claim or transfer rewards belonging to the Locker.

The surrogate nevertheless holds a material governance privilege. A malicious or compromised surrogate may submit votes that conflict with CLever's intended governance policy and economic interests.

The implementation does not enforce that the selected surrogate is an externally owned account. The Convex Registry authorizes an address rather than a specific account type, so an EOA-only requirement should be treated as an operational policy enforced through the owner governance process and voter runbook. This does not expand the authorization beyond the address explicitly selected by the owner.

4.4 Revocation and Replacement

The owner may revoke the current surrogate by calling:

```
setConvexVotingSurrogate(address(0));
```

The owner may replace it by setting a new address. After the Registry update, the previous surrogate can no longer submit new votes on behalf of the Locker.

Revocation does not automatically withdraw or amend votes that were submitted before the Registry update. If the relevant Vote Platform still permits vote changes, a newly authorized surrogate may submit a corrective vote. Otherwise, the previously submitted vote remains effective under that platform's rules.

4.5 Existing Gauge Delegation

At mainnet block `25,636,399`, the Gauge Delegation Registry returned the current Locker owner Safe, `0xFC08757c505eA28709dF66E54870fB6dE09f0C5E`, as the delegate of `CLeverCVXLocker` for epochs 229 and 230. The same Safe is also the owner of the Locker and its ProxyAdmin.

This delegation was created as part of Convex's existing migration state and was not introduced by PR #274. It allows the Safe to use the delegated Gauge weight while voting through its own voter account, but it does not allow the Safe to impersonate the Locker through the surrogate path. The Vote Platform adjusts the delegate's contribution when the Locker or its surrogate votes directly, preventing the same voting weight from being counted twice.

Because the Safe is already the Locker owner and ProxyAdmin owner, the existing delegation does not create a new privilege escalation. It does, however, constitute a second Gauge voting path and may affect voter identity, operational expectations, monitoring, and third-party incentive attribution.

Before production deployment, AladdinDAO should formally decide whether to:

- retain the owner Safe as an emergency Gauge-voting fallback and monitor its use; or
- adopt a surrogate-only model and arrange for the existing Gauge delegation to be revoked.

4.6 Legacy ABI Removal

The new implementation no longer exposes:

```
delegate(address registry, bytes32 id, address delegate);
commitUserSurrogate(address committer, address surrogate, address contractAddress);
```

This is a breaking ABI change. The Snapshot delegation path is obsolete under the new Convex voting process. However, permanent decommissioning of the legacy L2 committer path has not been independently confirmed as part of this review.

AladdinDAO should confirm that the L2 path has no remaining production dependency before deployment. If it remains necessary, the team should define an explicit compatibility or transition mechanism.

5. Operational Considerations

5.1 Voter Script Validation

The production voter script should:

- fix or strictly allowlist the `account` parameter to the `CLeverCVXLocker` address;
- discover the current DAO and Gauge Vote Platforms through the Convex Voting Registry;
- verify that each selected Vote Platform uses the expected Surrogate Registry;
- read `max_weight()` independently from each Vote Platform instead of assuming a shared precision;
- validate that the proposed weights sum to the platform-specific maximum;
- display the proposal, Locker account, gauges, and weights for review before broadcasting; and
- stop execution if any platform, Registry, account, or weight check does not match the approved configuration.

At the mainnet-state reference block, the DAO and Gauge Vote Platforms returned different `max_weight()` values: `10,000` and `1,000,000`, respectively. These values should be read from the active platforms at execution time rather than hard-coded from documentation.

5.2 Monitoring and Incident Response

AladdinDAO should:

- use a dedicated voter EOA that is not shared with treasury-management accounts;
- hold only the ETH required for voting transactions in that account;
- monitor surrogate changes in the shared Surrogate Registry;
- monitor `VoteCast` events for both the Locker and the owner Safe;
- stop the voter process immediately if the voter EOA is compromised; and
- revoke the affected surrogate before appointing a replacement.

After an incident, the team should inspect all active proposals and submit corrective votes where the relevant Vote Platform permits them.

5.3 Third-Party Incentive Attribution

The surrogate path records the Locker as the voter account, which is consistent with the intended attribution model. Nevertheless, Stake DAO, Votemarket, and other third-party platforms may use their own indexing, contribution-tracking, and settlement rules.

Accordingly, this report does not guarantee that voting incentives will be attributed or distributed to `CLeverCVXLocker`. AladdinDAO should obtain confirmation from each relevant platform before relying on that behavior in production.

6. Production Recommendations

Before production deployment, AladdinDAO should complete the following actions:

- validate the final production artifact and the complete Safe deployment calldata;
- confirm that the legacy L2 committer path has no remaining production dependency;
- formally choose whether to retain or revoke the existing Gauge delegation to the owner Safe;
- confirm incentive-attribution behavior with Stake DAO, Votemarket, and any other relevant platform;
- validate the voter script against the live Voting Registry, Surrogate Registry, and platform-specific `max_weight()` values; and
- configure monitoring for surrogate changes, Locker votes, and owner-Safe Gauge votes.

7. Review Result

No exploitable security vulnerabilities were identified in the source changes between `b8d232ba31abd2c815f5662e0bd99d26e09dd79a` and `25d83f1f34d0e59d41d11db7bc0ac137dc4dec35`.

The reviewed source changes are suitable for merge. Production deployment should proceed only after the operational, compatibility, external-dependency, and deployment-validation actions described in this report have been completed or formally accepted by AladdinDAO.